

Индивидуальный проект этап № 4

Использование nikto

Мальянц Виктория Кареновна

2026-04-02

1. Цель работы

2. Задание

3. Выполнение лабораторной работы

4. Выводы

5. Спасибо за внимание

1. 1. Цель работы



1. Цель работы

- Приобретение практических навыков по использованию nikto.

2. 2. Задание



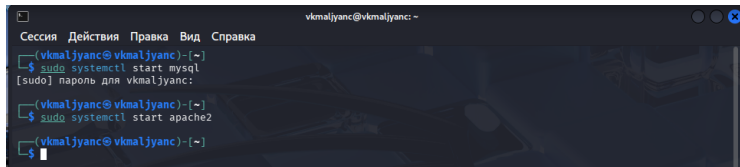
2. Задание

- Приобретение практических навыков по использованию nikto

3. 3. Выполнение лабораторной работы

3.1 Приобретение практических навыков по использованию nikto

- Запускаю mysql и apache2 (рис. 1).



```
vkmaljyanc@vkmaljyanc: ~  
Сессия Действия Правка Вид Справка  
(vkmaljyanc@vkmaljyanc)-[~]  
$ sudo systemctl start mysql  
[sudo] пароль для vkmaljyanc:  
(vkmaljyanc@vkmaljyanc)-[~]  
$ sudo systemctl start apache2  
(vkmaljyanc@vkmaljyanc)-[~]  
$
```

Рисунок 1: Запуск mysql и apache2

3.2 Приобретение практических навыков по использованию nikto

- Открываю DVWA и меняю уровень безопасности на Low (рис. 2).

The screenshot shows a web browser window with the DVWA Security application. The browser's address bar displays the URL `http://127.0.0.1/DVWA/security.php`. The page features a sidebar on the left with a list of attack categories: Home, Instructions, Setup / Reset DB, Bruteforce, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript Attacks, Authorisation Bypass, Open HTTP Redirect, and Cryptography. The main content area is titled 'DVWA Security' and 'Security Level'. It states that the current security level is 'low'. Below this, a list of four security levels is provided: 1. Low - This security level is completely vulnerable and has no security measures at all. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques. 2. Medium - This setting is mainly to give an example to the user of bad security practices, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques. 3. High - This option is an extension to the medium difficulty, with a mixture of harder or alternative bad practices to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions. 4. Impossible - This level should be secure against all vulnerabilities. It is used to compare the vulnerable source code to the secure source code. Prior to DVWA v1.9, this level was known as 'high'. A dropdown menu is set to 'Low' and a 'Submit' button is visible. The 'Additional Tools' section includes a link to 'View Broken Access Control Logs' - View access logs for the Broken Access Control vulnerability. At the bottom, a text box indicates 'Security level set to low'.

3.3 Приобретение практических навыков по использованию nikto

- Запускаю nikto (рис. 3).

A terminal window with a dark background. The prompt is '(vkmaljjanc@vkmaljjanc)~'. The command '#nikto' has been entered and is highlighted in blue. The terminal shows the command being executed in a shell environment.

```
(vkmaljjanc@vkmaljjanc)~  
$ #nikto
```

Рисунок 3: Запуск nikto

3.4 Приобретение практических навыков по использованию nikto

- Проверяю веб-приложение, сканирую его, введя его полный URL (рис. 4).

```
(vkmaljjanc@vkmaljjanc)~$  
$ nikto -h http://127.0.0.1/DVWA/  
- Nikto v2.5.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Start Time: 2026-04-02 11:20:52 (GMT3)  
  
+ Server: Apache/2.4.65 (Debian)  
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ Root page /DVWA redirects to: login.php  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .  
+ /DVWA///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.  
+ /DVWA/config/: Directory indexing found.  
+ /DVWA/config/: Configuration information may be available remotely.  
+ /DVWA/tests/: Directory indexing found.  
+ /DVWA/tests/: This might be interesting.  
+ /DVWA/database/: Directory indexing found.  
+ /DVWA/database/: Database directory found.  
+ /DVWA/docs/: Directory indexing found.  
+ /DVWA/login.php: Admin login page/section found.  
+ /DVWA/.git/index: Git Index file may contain directory listing information.  
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.  
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.  
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.  
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /DVWA/wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /DVWA/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /DVWA/wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /DVWA/assets/mobirise/css/meia.php?filesrc=: A PHP backdoor file manager was found.
```

3.5 Приобретение практических навыков по использованию nikto

- Проверяю веб-приложение, сканирую его, введя адрес хоста и адреса порта (рис. 5).

```
(vkmaljanc@vkmaljanc)~$ nikto -h 127.0.0.1 -p 80
- Nikto v2.5.0

+ Target IP:      127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port:    80
+ Start Time:     2026-04-02 11:21:44 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HT
TTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site
in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mi
ssing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 64ba9832af336, mtime: gzip. See:
http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ ///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict a
ccess to allowed sources. See: OSVDB-561
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found
.
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager
was found.
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found
.
+ /assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.
+ /login.cgi?cli=aa%20aa%27cat%20/etc/hosts: Some D-Link router remote command execution.
+ /shell?cat=/etc/hosts: A backdoor was identified.
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host
+ End Time:      2026-04-02 11:21:55 (GMT3) (11 seconds)
```

Рисунок 5: Проверка веб-приложения, сканирование его, ввод адреса хоста и адреса порта

4. 4. Выводы

- Я приобрела практические навыки по использованию nikto.

5. 5. Спасибо за внимание
